Source: https://codetrappers.com/ai-security-governance/

Know what your AI can reach, and be able to prove it

What your AI can reach, who approved it, and whether you could prove it to an auditor. Permission review, prompt injection testing, audit logging and a data flow map.

A review of what is connected to what, who approved it, what it is allowed to do, and what it would take to demonstrate that to a client, an auditor or a regulator.

Get in touch (https://codetrappers.com/contact/) Book a consultation (https://cal.com/yusuf-mudagal-6abk5h/30min)

- 300+ migrations, zero data loss
- Core Web Vitals in the green
- 24/7 emergency cover

What you get

Inside AI Security and Governance

Get in touch (https://codetrappers.com/contact/)

Inventory what is actually connected

Most organisations underestimate this. Assistants added to a helpdesk, an API key in an automation tool, a plugin someone installed. The list is longer than the one anybody remembers.

Reduce every credential to least privilege

Integrations are usually built with an admin token because that made the first demo work. Each one gets scoped down to the capabilities it genuinely needs.

Log every call in a form a person can read

Which tool, which arguments, whose credentials, what changed. This is the difference between an incident you can explain and one you cannot.

Test what happens with hostile input

Instructions hidden in a web page, a support ticket or an uploaded document are the current attack. We try them against your setup rather than assuming the model resists.

Write a policy people can actually follow

Which tools are approved, what data may go into them, who signs off a new one, and what happens when something goes wrong. Short enough to be read.

The service

What we deliver

An access and permission review

Every AI integration, what it can reach, and a scoped-down recommendation for each.

Prompt injection testing

Adversarial input through the routes your system actually accepts content from, with the results written up.

Audit logging

Built where it does not exist, retained for a period that matches your obligations rather than your disk space.

A data flow map

What leaves your systems, to which processor, under what basis. The input a DPIA needs, and the answer to the question procurement always asks.

Consent and disclosure review

Whether your cookie banner, privacy policy and AI disclosures describe what your site actually does. In our experience they usually do not, and that gap is cheap to close.

An incident runbook

What to disconnect first, who to tell, and how to work out what the agent touched. Written before you need it.

Why CodeTrappers

The failures we see most

None of these are exotic. All of them are common.

One over-permissioned key doing everything

Created for a proof of concept, never scoped down, now in production and shared between three tools.

Tool output trusted as instruction

An agent that treats text from a scraped page or a customer ticket as a command can be steered by anyone able to write into that system.

A policy that describes a different site

Analytics and advertising loading before consent while the policy says otherwise is the single most common finding, and one of the easiest to fix.

Get in touch (https://codetrappers.com/contact/) Book a consultation (https://cal.com/yusuf-mudagal-6abk5h/30min)

Questions

What people ask before they start

Something not covered here? Ask us directly and an engineer will answer.

Ask a question (https://codetrappers.com/contact/)

Everything connected to your systems through an assistant, an API key or an automation tool, what each one can reach, and whether you could demonstrate that to a client or an auditor. Most organisations find the list longer than the one anybody remembered.

If an agent reads anything a third party can write, yes. Text in a web page, a support ticket or an uploaded document is data, not instruction, and an agent that does not draw that line can be steered by anyone able to write into that system. We test it rather than assume the model resists.

Only if it describes what your site actually does. The most common finding we see is analytics and advertising loading before consent while the policy says otherwise, which is cheap to close once somebody looks.

A permission review with a scoped-down recommendation per integration, the results of injection testing, audit logging where none exists, a data flow map that answers the question procurement always asks, and an incident runbook written before you need it. This work settles what a system may reach and who approved it, before launch. What it actually did and what it cost afterwards is AI monitoring and observability (https://codetrappers.com/ai-monitoring-observability/).

Start here

Ready to get started with AI Security and Governance?

Tell us what you need. We'll come back with a plan and a fixed price, usually within a day.

Get in touch (https://codetrappers.com/contact/) Book a consultation (https://cal.com/yusuf-mudagal-6abk5h/30min)

- A free audit first

We'll look at your site and tell you straight what needs doing.

- Fixed scope, fixed price

Agreed in writing before any work starts. No hidden fees.

- A real engineer on the call

You talk to the people who do the work, not a sales script.